

클라우드 보안 진단 리포트

1. 진단 요약

- 전체 점검 수: 23
- 양호 항목 수: 12
- 취약 항목 수: 11
- 보안 점수: 54
- 종합 의견: 현재 클라우드 환경은 전반적으로 보안 점수가 낮으며, 특히 관리자 계정 권한 관리, 로깅 설정, 다중 인증(MFA) 적용, 비밀번호 정책 설정 등 기본적인 보안 설정에 대한 미흡한 부분이 다수 발견되었습니다. 이는 계정 탈취 및 비인가 접근으로 인한 심각한 보안 사고로 이어질 수 있으므로, 제시된 취약점들에 대한 신속하고 체계적인 조치가 필요합니다.

2. 우선 조치 대상

위험도와 영향도를 기준으로 우선 조치해야 할 항목을 정리합니다.

- IAM Admin User (admin, test1, test2, test3):** 최고 관리자 권한을 가진 계정이 서비스 운영 용도로 사용될 경우 모든 AWS 서비스에 접근 가능하여 심각한 보안 위험을 초래할 수 있습니다.
- Root Account MFA Enabled:** 루트 계정에 다중 인증(MFA)이 설정되어 있지 않아 계정 탈취 시 심각한 피해가 발생할 수 있습니다.
- CloudTrail Enabled:** 사용자 활동 로그가 기록되지 않아 보안 사고 발생 시 원인 분석 및 추적이 불가능합니다.

3. 상세 취약점 분석

IAM Admin User

점검 항목

- 진단 항목: IAM Admin User

- 대상: admin
- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK실더스 가이드 항목: 1.7

원인 분석

admin 사용자는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User

점검 항목

- 진단 항목: IAM Admin User
- 대상: test1
- 위험도: 상

- KISA 코드: KISA-CLD-12
- SK실더스 가이드 항목: 1.7

원인 분석

test1 사용자는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User

점검 항목

- 진단 항목: IAM Admin User
- 대상: test2
- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK실더스 가이드 항목: 1.7

원인 분석

test2 사용자는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User

점검 항목

- 진단 항목: IAM Admin User
- 대상: test3
- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK윌더스 가이드 항목: 1.7

원인 분석

test3 사용자는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

CloudTrail Enabled

점검 항목

- 진단 항목: CloudTrail Enabled
- 대상: CloudTrail
- 위험도: 상
- KISA 코드: KISA-CLD-08
- SK실더스 가이드 항목: 4.7

원인 분석

설정된 CloudTrail 트레일이 없습니다.

보안 영향

AWS 사용자 계정의 활동 로그가 수집되지 않아 보안 사고 발생 시 원인 분석, 이상 행위 탐지, 접근 이력 추적이 불가능합니다.

단계별 조치 가이드

1. CloudTrail 콘솔로 이동합니다.
2. 새 추적을 생성하거나 기존 추적 설정을 확인합니다.
3. 관리 이벤트 로깅을 활성화합니다.
4. 로그 저장용 S3 버킷을 지정합니다.
5. 필요 시 CloudWatch Logs 연동을 설정합니다.

조치 후 확인 방법

1. CloudTrail 트레일이 존재하는지 확인합니다.
2. 최근 사용자 활동 이벤트가 기록되는지 확인합니다.
3. 로그 저장 대상 S3 버킷에 로그가 생성되는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 4.7 AWS 사용자 계정 로깅 설정

Root Account MFA Enabled

점검 항목

- 진단 항목: Root Account MFA Enabled
- 대상: Root Account
- 위험도: 상
- KISA 코드: KISA-CLD-08
- SK윌더스 가이드 항목: 1.9

원인 분석

루트 계정에 MFA가 설정되어 있지 않습니다.

보안 영향

MFA가 설정되어 있지 않은 루트 계정은 비밀번호만으로 접근이 가능하여 계정 탈취 시 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM User MFA Enabled

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: admin
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK윌더스 가이드 항목: 1.9

원인 분석

admin 사용자는 MFA가 설정되어 있지 않습니다.

보안 영향

MFA가 설정되어 있지 않은 admin 계정은 비밀번호만으로 접근이 가능하여 계정 탈취 시 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM User MFA Enabled

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: test1
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK윌더스 가이드 항목: 1.9

원인 분석

test1 사용자는 MFA가 설정되어 있지 않습니다.

보안 영향

MFA가 설정되어 있지 않은 test1 계정은 비밀번호만으로 접근이 가능하여 계정 탈취 시 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.

2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM User MFA Enabled

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: test2
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK실더스 가이드 항목: 1.9

원인 분석

test2 사용자는 MFA가 설정되어 있지 않습니다.

보안 영향

MFA가 설정되어 있지 않은 test2 계정은 비밀번호만으로 접근이 가능하여 계정 탈취 시 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.

4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM User MFA Enabled

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: test3
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK실더스 가이드 항목: 1.9

원인 분석

test3 사용자는 MFA가 설정되어 있지 않습니다.

보안 영향

MFA가 설정되어 있지 않은 test3 계정은 비밀번호만으로 접근이 가능하여 계정 탈취 시 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM Password Policy

점검 항목

- 진단 항목: IAM Password Policy
- 대상: Account
- 위험도: 중
- KISA 코드: KISA-CLD-09
- SK윌더스 가이드 항목: 1.10

원인 분석

IAM 계정 비밀번호 정책이 설정되어 있지 않습니다.

보안 영향

비밀번호 정책이 설정되어 있지 않으면 사용자가 추측하기 쉬운 비밀번호를 사용하거나, 비밀번호 변경 주기가 길어질 경우 계정 탈취 위험이 높아집니다.

단계별 조치 가이드

1. IAM 콘솔에서 계정 설정 또는 암호 정책 메뉴로 이동합니다.
2. 최소 비밀번호 길이를 설정합니다.
3. 대문자, 소문자, 숫자, 특수문자 요구 조건을 설정합니다.
4. 비밀번호 만료 기간과 재사용 방지 정책을 설정합니다.
5. 변경된 정책이 IAM 사용자에게 적용되는지 확인합니다.

조치 후 확인 방법

1. IAM 비밀번호 정책이 활성화되어 있는지 확인합니다.

2. 복잡도와 만료 주기가 보안 기준에 맞는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.10 AWS 계정 패스워드 정책 관리